

Honeypots & Deception

What deception buys you

The attacker who thinks they reach a server actually reaches a tripwire. Defense gets: early warning, attacker TTP visibility, and wasted attacker time.

The family

Type	Tool/approach	Value
Low-interaction	Cowrie (SSH), Honeyd (fake TCP), dionaea (service)	Cheap, safe, false-normal
High-interaction	Real VMs the attacker abuses	Deep TTPs, risk of harming neighbors
Canary tokens	thinkst tokens: fake strings/URLs/QR with callback	Instant phishing/leak tripwire
Fake data	decoy DB records, fake creds in memory	Detect access to 'poisoned' data

Hands-on: Cowrie SSH honeypot

```
sudo apt install -y cowrie
# edit cowrie.cfg listen_port = 2222 (non-priv)
sudo -u cowrie cowrie start
# A test-attacker SSH-brute/login to port 2222 gets... a fake shell.
# Watch logs: /var/log/cowrie/cowrie.json + logs/ssh-...tie
```

Every 'whoami', 'uname', 'cat' answer is recorded; credentials captured as structs it logs attempted usernames/passwords.

Canary tokens quick win

Generate a token URL (thinkst / canarytokens spec)

Drop the URL into a low-traffic internal doc (or fake credential in a config backup)

If anything 'clicks' the URL → you get a callback ping with source IP
Cheap, near-zero maintenance, catches real pivots

Positioning

Place honeypots "inside the reach" of common pivots (a server with weak SSH, a fake backup share, a token in the 'service account' file)

MONITOR the honeypot traffic; the value is the alert + TTP PE

Never poison production data; decoy records must be marked/inert

A honeypot's value is proportional to its realism AND its observers.
Unowned decoys are just more junk to attackers.

← IDS/IPS & Firewall Evasion

Anonymization: VPN, Tor, Proxi...